CYBERSECURITY INCIDENT REPORT

Ransomware Attack and Data Breach

Orion Health Services | Executive Leadership Briefing

TO	Executive Leadership Team
FROM	Cybersecurity Analyst Graduate
DATE	October 31, 2026
SUBJECT	Incident Report: Ransomware Attack and Data Breach

INCIDENT STATUS

Severe ransomware incident involving encryption of critical systems and potential exposure of patient and employee information. The scope of data exfiltration, affected assets, and recovery status must be confirmed through forensic investigation.

Handling note: This report is based on the incident information supplied for assessment. Technical findings, affected asset counts, exfiltration claims, and applicable notification obligations should be validated by the incident response team, legal counsel, and privacy leadership.

1. Executive Summary

On Monday morning, Orion Health Services experienced a severe ransomware incident that encrypted critical systems and raised concerns about the possible exfiltration of sensitive patient and employee information. The reported initial access vector was a phishing email opened by a member of the Finance team.

The incident has affected core file services and HR/Finance systems, with partial encryption also reported on the backup server. The reported ransomware file extension is **.orionlock**. The attacker is also reported to have accessed Windows credential material and used legitimate credentials to move laterally through the environment.

Priority: Contain the incident, preserve evidence, establish the full scope of compromise, protect remaining recovery assets, and assess whether regulated personal information was accessed or exfiltrated.

Incident at a Glance

AREA	CURRENT REPORTED POSITION
Initial access	Phishing email with a malicious Excel attachment sent to Finance.
Credential activity	Mimikatz reportedly used to extract credential material from Windows LSASS memory.
Affected systems	File server, HR/Finance systems, and partially encrypted backup server.
Ransomware indicator	Files carrying the **.orionlock** extension.
Data exposure	Potential exposure of patient schedules and employee payroll/personnel records; exfiltration not yet confirmed.

2. Incident Analysis and Attack Vector

The sequence below reflects the currently reported attack path. The precise timeline and technical details require confirmation from endpoint, identity, network, and server logs.

STAGE	REPORTED ACTIVITY
1. Initial access	A phishing email containing a malicious Excel attachment was delivered to Finance and opened by a team member.
2. Credential access	The attachment reportedly triggered malware execution. Mimikatz was then used to obtain credential material from Windows LSASS memory.
3. Lateral movement	The attacker reportedly used compromised credentials to access additional systems and move across the network.
4. Ransomware impact	Ransomware using the **.orionlock** extension encrypted the file server and HR/Finance systems, and partially encrypted the backup server.

3. Business Impact and Ramifications

Financial and Legal

- Potential regulatory exposure if patient or employee information was accessed, disclosed, or inadequately protected. Applicable requirements depend on jurisdictions, data types, and entities involved; privacy counsel should determine notification and reporting duties.
- Significant response costs may include forensic investigation, specialist incident response, system restoration, legal advice, business interruption, and potential contractual liabilities.

Reputational and Operational

- Loss of confidence among patients, employees, healthcare partners, and clinic customers could affect renewals, contracts, and future business.

- Unavailable file, HR, and Finance services may disrupt internal operations and service delivery. The duration and extent of disruption remain to be established.

3. Business Impact and Ramifications (continued)

Employee and Patient Privacy

- Employee payroll and personnel records may contain home addresses, bank details, and tax identifiers. If exposed, these details could increase the risk of identity fraud, targeted scams, extortion, or personal safety concerns.
- Patient schedules and related records can reveal sensitive information about individuals' appointments and care. Access and disclosure must be assessed and handled as a privacy incident.

4. Indicators of Compromise (IOCs)

The following indicators have been reported and should guide evidence collection and threat hunting. Validate each indicator against original telemetry before treating it as confirmed.

INDICATOR	INVESTIGATION FOCUS
Unusual overseas login attempts	Review identity provider, VPN, cloud, and domain authentication logs; correlate source IPs, accounts, timestamps, and anomalous sign-in patterns.
Mimikatz execution	Review endpoint telemetry, process execution records, EDR alerts, and memory-access events on affected endpoints.
Files with **.orionlock** extension	Identify affected hosts, file paths, timestamps, and encryption scope. Preserve representative samples as evidence in a controlled environment.
Unusual outbound traffic	Examine firewall, proxy, DNS, and network-flow records for anomalous destinations, transfer volumes, and suspicious timing.

5. Recommendations and Remediation

Immediate actions should be coordinated by the incident commander. Preserve forensic evidence and document affected assets, containment steps, and key decisions.

A. Immediate Containment and Evidence Preservation

- **Isolate affected systems:** Remove confirmed-compromised file, HR, and Finance servers from the network using approved incident response procedures. Avoid powering systems off unless directed by the response lead, as volatile evidence may be lost.
- **Protect recovery assets:** Restrict network access to the partially encrypted backup server and isolate it from potentially compromised systems. Validate backup integrity and prevent further modification.
- **Preserve evidence:** Retain relevant email samples, endpoint telemetry, authentication logs, network records, and forensic images in accordance with evidence-handling procedures.
- **Assess exfiltration:** Determine whether data left the environment, what data was involved, and which individuals or organizations may be affected.

B. Identity and Access Management

- **Contain compromised identities:** Disable or restrict accounts confirmed or reasonably suspected to be compromised, revoke active sessions and tokens, and review privileged access.
- **Rotate credentials safely:** Prioritize privileged, service, administrator, and affected user credentials. Coordinate broader password resets after containment and perform resets from trusted, clean devices.
- **Enforce MFA:** Require phishing-resistant MFA where feasible, particularly for administrators, remote access, email, and critical business systems. MFA reduces account-takeover risk but does not replace endpoint and credential protections.

5. Recommendations and Remediation (continued)

C. Endpoint Detection and Response (EDR)

- **Deploy or tune EDR:** Ensure endpoint monitoring and response coverage across servers and workstations, prioritizing high-value assets.
- **Harden credential protection:** Enable supported Windows protections, such as Credential Guard and LSASS protection, where compatible; monitor suspicious access to LSASS and credential-dumping behaviors.
- **Investigate before rebuilding:** Identify persistence, malicious processes, and the full scope of compromise before restoring affected systems.

D. Recovery, Governance, and Awareness

- **Restore securely:** Rebuild from known-good images and restore only from verified clean backups. Validate systems before reconnecting them to production networks.
- **Meet legal and contractual duties:** Engage privacy, legal, compliance, and communications teams to determine notification obligations and prepare consistent stakeholder communications.
- **Targeted awareness training:** Provide mandatory, role-specific phishing training for Finance and HR, including safe handling of unexpected spreadsheets, recruitment files, payroll requests, and external documents.
- **Test resilience:** Review email security controls, least-privilege access, network segmentation, backup isolation, patching, and incident response playbooks.

Recommended Priority

PRIORITY	FOCUS	EXPECTED OUTCOME
Immediate	Contain affected assets; protect backups; preserve evidence; restrict compromised accounts.	Limit further encryption and unauthorized access.
Next 24–72 hours	Establish scope; assess data exposure; rotate critical credentials; coordinate legal/privacy review.	Clarify impact and reduce ongoing risk.
Recovery phase	Rebuild clean systems; validate backups; restore services in controlled stages.	Resume operations safely.
Longer term	Improve MFA, EDR, segmentation, backup resilience, and targeted training.	Reduce likelihood and impact of recurrence.

6. Conclusion

The reported incident presents a serious threat to Orion Health Services' operational continuity, information security, and stakeholder trust. The immediate response must focus on containment, evidence preservation, protection of recovery assets, and determining whether sensitive information was exfiltrated. A coordinated recovery and improvement programme—supported by executive oversight, technical controls, and targeted employee awareness—will be essential to restoring services and reducing the risk of recurrence.

> **EXECUTIVE DECISION REQUIRED**
> **Authorize the incident response team to execute containment and recovery actions, engage specialist forensic and legal support as required, and provide leadership with regular updates on scope, data exposure, operational impact, and recovery progress.**